

AUTHENTIX v2.1.0

Next-Generation Authentication, IDOR/BOLA & Secret Scanner Security Suite

Architect & Author: Pratik Sanjay Khairnar (Cyber Security Researcher & Security Tool Developer)

Platform: PortSwigger Burp Suite (Native Montoya API) • Java 17/21 • Deterministic Finite-State Automaton

Core Capabilities: 27 Invariants • 28 Secret Rules • Cross-Actor Matrix • 12 ATO Chains • NimbusBank v2 Lab

Executive Demo Portal: <https://pratik-khairnar-sec.github.io/authentix-enterprise/>

Slide 02: The Authentication Blindspot in Modern AppSec

Why Traditional DAST Scanners and Legacy Burp Extensions Fall Short

- **Stateless Limitation:** Modern scanners treat HTTP requests as isolated transactions, completely blind to state-machine dependencies across multi-step authentication flows (login, OTP, session, password reset).
- **Legacy Tool Gaps:** Tools like AuthMatrix and Autorize only test simple cookie-swapping on isolated endpoints. They cannot track token lifetime decay, detect client-trust bypasses, or evaluate entropy floor violations.
- **Compound Attack Misses:** High-severity breaches are rarely single requests; they are multi-step kill chains (e.g., User Enumeration + Host Header Poisoning + Token Reuse = Account Takeover).
- **False Positives vs True Positives:** Noisy heuristics waste analyst time. AppSec requires mathematically verifiable, evidence-gated security invariants.

Slide 03: Architectural Breakthrough: PortSwigger Montoya API

Native High-Throughput Engine with Non-Blocking Asynchronous Processing

- **Montoya API Foundation:** Built on PortSwigger's latest Montoya API, guaranteeing native integration with Burp Proxy, Repeater, Scanner, and Intruder without legacy API overhead.
- **Per-Actor Isolation:** Incoming traffic is parsed and attributed to discrete actor state machines (Anonymous, Victim, Attacker, Administrator).
- **Zero UI Latency:** Multi-threaded worker pools decouple deep packet inspection, regex analysis, and graph calculations from Burp's main rendering thread.
- **Direct C2 Telemetry:** Automated Telegram Bot dispatcher streams verified findings with terminal-ready Kali Linux cURL reproduction commands in real time.

Slide 04: Finite State Automaton & Token Lifecycle Engine

Mathematical State Tracking and Shannon Entropy Analysis

- **State Machine Modeling:** Transitions between Unauthenticated, Credential Verified, MFA Required, Session Active, and Terminated states are verified continuously.
- **Cryptographic Fingerprinting:** Sensitive tokens (JWTs, session IDs, reset hashes) are hashed via SHA-256 for tracking; raw secrets are never persisted in plaintext.
- **Shannon Entropy Verification:** Verifies that pseudo-random tokens maintain cryptographic entropy (≥ 3.8 bits/byte) to prevent PRNG predictability attacks.
- **Single-Use & Replay Defense:** Detects when an OTP or password reset token is accepted multiple times across independent session lifetimes.

Slide 05: The 27 Evidence-Gated Security Invariants

Formal Inviolable Rules Across All Authentication & API Surfaces

Category	Invariants Included	Key Protections
OTP / MFA (INV 01-04)	Lifetime Bound, Single-Use, Rate-Limit, Client-Bypass	Prevents OTP replay, brute-force bypass, and client-side status spoofing
Session (INV 05-07, 23)	Pre-Auth Fixation, Post-Logout Revoke, Max Sessions, Flags	Guarantees clean session rotation and enforces Secure/HttpOnly/SameSite
Authorization (INV 08-09, 19, 26)	IDOR Matrix, Sequential IDs, BFLA, Client-Role Trust	Automates cross-actor privilege boundary testing and horizontal/vertical IDOR
Password Reset (INV 10-14, 24)	Single-Use, Host Poisoning, Re-Auth, Lifetime, User Enum	Eliminates reset poisoning, token reuse, and timing-based user harvesting
JWT & Crypto (INV 15-18, 27)	Alg None, Expiry, Weak HMAC, Refresh Rotation, Entropy	Blocks algorithm confusion, expired claims, weak secrets, and PRNG flaws

Slide 06: Automated Cross-Actor Authorization Matrix (IDOR / BOLA)

Zero-Configuration Horizontal & Vertical Privilege Escalation Mapping

- **Autonomous Object Identification:** Automatically parses REST URL path segments, JSON request bodies, and query parameters for object identifiers (sequential integers, UUIDv4, custom hashes).
- **Multi-Actor Cross-Replay:** Replays privileged requests under alternative actor contexts (Attacker → Victim, Standard User → Admin).
- **Differential Content Analysis:** Validates status code, response body entropy, content length, and JSON schema to confirm unauthorized access with zero false positives.
- **Interactive Burp Matrix UI:** Displays findings in a high-contrast Swing matrix tab with one-click export to Markdown, JSON, and PDF.

Slide 07: 28 Deep Secret Analysis Rules Engine

High-Speed Regex & Cryptographic Heuristics for Exposed Credentials

- **Cloud Service Providers:** Deep pattern matching for AWS Access Keys, Google Cloud Service Account JSON, and Azure Shared Access Signatures.
- **AI & LLM API Keys:** Detects embedded OpenAI (sk-...), Anthropic Claude, and Cohere API tokens in client-side bundles.
- **Payment Gateways:** Identifies Stripe Live/Test secrets, PayPal Client IDs, and Razorpay API keys.
- **Infrastructure & Database:** Extracts Telegram Bot tokens, Firebase Database URLs, GitHub Personal Access Tokens, and database connection strings.

Slide 08: 12 Correlated Account Takeover (ATO) Kill Chains

Synthesizing Disparate Invariants into Actionable High-Impact Narratives

- **Graph-Based Correlation:** AttackPathCorrelator.java builds directed acyclic graphs connecting related findings.
- **ATO-01 (Host Header Poisoning):** User Enumeration → Host Header Reset Poisoning → Single-Use Violation → Complete Account Compromise.
- **ATO-02 (Client-Trust 2FA Bypass):** Pre-Auth Session Fixation → Client-Side OTP Status Spoof → Step-Up Bypass.
- **ATO-03 (JWT Key Confusion):** Hardcoded JWT Secret → Algorithm 'none' Signature Strip → Admin Role Escalation.
- **ATO-04 (Mass BOLA Exfiltration):** Predictable Sequential ID → IDOR Matrix Access → Full Tenant Data Harvest.

Slide 09: Enterprise Testbed: NimbusBank v2

Empirical Verification on a Full-Scale Financial Application Testbed

- **Target Architecture:** Production-grade banking core engineered with 16 planted multi-step vulnerabilities.
- **Planted Vectors:** OTP replay, step-up transfer bypass, cross-user wire transfer IDOR, JWT tampering, and admin role assumption.
- **Empirical Results:** AUTHENTIX achieved a 100% detection rate (16/16 vulnerabilities identified).
- **Noise Rejection:** Evaluated against 1,450 legitimate banking transactions with zero false positives.

Slide 10: Real-Time Telemetry & Telegram C2 Dispatcher

Instant Incident Response Alerts with Terminal-Ready Reproduction Proofs

- **Instant Mobile Notifications:** Pushes critical findings directly to security team channels via Telegram Bot API within 120ms of detection.
- **Kali Linux cURL PoCs:** Every finding includes a complete, copy-paste cURL command with exact headers and payloads for immediate verification.
- **CVSS 3.1 Scoring:** Automatically computes dynamic vector scores based on exploit path complexity and privilege escalation potential.
- **Zero Infrastructure Requirement:** Operates completely client-side inside Burp Suite without external relay dependencies.

Slide 11: Executive Conclusion & Engagement Summary

Transforming Authentication Security from Art to Deterministic Engineering

- **Enterprise Impact:** Eliminates the \$4.45M average cost of data breaches resulting from broken authentication and IDOR.
- **Comprehensive Suite:** 27 formal invariants, 28 secret rules, and 12 compound attack chains in a single, high-performance Burp Suite extension.
- **Engineered by Pratik Khairnar:** Cyber Security Researcher, AppSec Engineer, and Security Tool Developer.
- **Interactive Portal:** Explore live interactive sandboxes at <https://pratik-khairnar-sec.github.io/authentix-enterprise/>
- **Connect on GitHub:** <https://github.com/pratik-khairnar-sec>